

Post-Quantum Hybrid KEMs in the ZAP Transport Handshake: A Security Analysis of X-WING and Z-WING

ZAP Protocol Authors
zap-proto.io

May 6, 2026

Abstract

The ZAP transport protocol provides authenticated, confidential channels with both ephemeral and long-lived sessions. To resist *harvest-now-decrypt-later* (HNDL) attackers and to absorb future cryptanalytic surprises in either the elliptic-curve or lattice settings, ZAP adopts a layered family of hybrid key-encapsulation mechanisms (KEMs). The base layer, X-WING, combines X25519 with ML-KEM-768 in a single shared-secret KEM whose IND-CCA2 security holds when *either* component is sound. For long-lived sessions and protected long-term identity keys, ZAP additionally specifies Z-WING, a triple-hybrid that compounds X-WING with a third, conservatively chosen KEM. We give a formal definition of Z-WING, a robust combiner construction, and a tight reduction proving IND-CCA2-AKE security of the resulting authenticated key exchange. We argue why ML-KEM-1024 is the right third component for performance-conscious deployments, and we give the engineering budget (handshake bytes, CPU cycles) versus a curve-only baseline.

1 Introduction

The ZAP transport handshake is a mutually authenticated key exchange used to establish forward-secret session keys between peers that already know each other’s long-term static public-key fingerprints. Like Noise-style protocols, ZAP is NIKE-flavoured: each side contributes a long-term static KEM keypair and a per-session ephemeral KEM keypair, and the resulting transport key is derived from a transcript of all KEM operations.

Two design pressures pushed ZAP away from a curve-only handshake. First, *harvest-now-decrypt-later* [1]: an adversary that records ciphertext today retains the option to decrypt once a cryptographically-relevant quantum computer (CRQC) becomes available. ZAP is intended for sessions with multi-year confidentiality requirements and for long-term identity keys whose rotation is operationally expensive. Second, lattice cryptanalysis is younger than elliptic-curve cryptanalysis: prudent deployment composes the two so that a break of *either* primitive does not break the channel.

The first hybrid KEM ZAP adopts is X-WING [2], the IETF/CFRG-tracked X25519 || ML-KEM-768 construction. For high-assurance, long-lived sessions and for protection of static authentication keys, ZAP specifies a second hybrid, Z-WING, that folds an additional KEM into X-WING via a robust combiner. The construction is conservative: it strictly retains X-WING’s “one of the component KEMs is sound” property while admitting a third independent component whose mathematical assumptions differ from those of X-WING’s two existing components.

Contributions.

- We give a formal description of Z-WING as a KEM and as the keying agent of the ZAP authenticated handshake (Section 4).

- We prove IND-CCA2 security of Z-WING under the assumption that any one of its three component KEMs is IND-CCA2 secure and that the KDF combiner is a random oracle (Section 5; full reduction in the companion proof).
- We bound the AKE advantage of an active adversary against the ZAP handshake instantiated with Z-WING in terms of the underlying KEM and KDF advantages, with explicit hops.
- We quantify the wire and CPU cost (Section 7) and argue the ML-KEM-1024 choice for the third slot.

2 Threat Model

We use a Bellare-Rogaway-style AKE security model with corruption oracles, following the formulations used in the symbolic and computational analyses of TLS 1.3 [3] and the hybrid-AKE setting of [4].

Network adversary. The adversary $\mathcal{A}$ controls all network traffic and may delay, drop, replay, reorder, inject, or modify any message. ZAP provides no in-band confidentiality of the handshake itself beyond what KEM ciphertexts give.

Corruption oracles. The adversary may issue:

- $\text{StaticReveal}(P)$: reveal the long-term KEM secret of party P .
- $\text{EphemeralReveal}(\pi)$: reveal the ephemeral KEM secret of a specific session π .
- $\text{SessionKeyReveal}(\pi)$: reveal the derived transport key of a completed session.
- $\text{Test}(\pi)$: against a fresh, partnered session, return either the real key or a uniformly random key of the same length.

Future quantum. We assume $\mathcal{A}$ may, at any point in the future, become quantum and decrypt previously recorded ciphertexts. This is captured by a single “post-quantum” transition in the game sequence: classical KEM hardness assumptions are replaced by their PQ counterparts where applicable. The hybrid construction is what insulates the session secret against this transition. We do not need additional UC-style machinery for the HNDL setting; the standard freshness conditions on the test session, lifted to the hybrid KEM, suffice.

Freshness. A test session π is fresh if (i) its transport key has not been revealed, (ii) its partner session’s transport key has not been revealed, and (iii) for at least one component KEM among $\{\text{X25519}, \text{ML-KEM-768}, \text{ML-KEM-1024}\}$, neither party’s contribution to that component within the session was learnt by $\mathcal{A}$ via static or ephemeral reveal. Condition (iii) is the hybrid relaxation: the AKE remains secure as long as one of the three components remains uncompromised *for that session*.

IND-CCA2-AKE. The advantage of $\mathcal{A}$ is $\text{Adv}_{\text{ZAP}}^{\text{ake}}(\mathcal{A}) = |\Pr[b' = b] - 1/2|$ in the standard test-session-prediction game.

3 X-Wing Recap

X-WING [2] is a hybrid KEM with the following pseudocode. Let $(pk_x, sk_x) \leftarrow \text{X25519.KGen}$ and $(pk_m, sk_m) \leftarrow \text{ML-KEM.KGen}$.

- **KGen**: output $pk = (pk_x, pk_m)$, $sk = (sk_x, sk_m, pk_x, pk_m)$.
- **Encap**(pk): sample ephemeral $(pk'_x, sk'_x) \leftarrow \text{X25519.KGen}$; $ss_x \leftarrow \text{X25519.DH}(sk'_x, pk_x)$; $(c_m, ss_m) \leftarrow \text{ML-KEM.Encap}(pk_m)$; $ss \leftarrow \text{SHA3-256}(\text{label} \parallel ss_m \parallel ss_x \parallel c_m \parallel pk'_x \parallel pk_m)$; output ciphertext $c = (c_m, pk'_x)$ and shared secret ss .
- **Decap**(sk, c): parse $c = (c_m, pk'_x)$; $ss_x \leftarrow \text{X25519.DH}(sk_x, pk'_x)$; $ss_m \leftarrow \text{ML-KEM.Decap}(sk_m, c_m)$; recompute ss as above.

X-WING achieves IND-CCA2 security if either X25519 is OW-CPA-secure or ML-KEM-768 is IND-CCA2-secure, with the binding to c_m, pk'_x, pk_m inside the KDF closing the obvious cross-component-malleability and binding gaps identified in [5].

4 Z-Wing Construction

Z-WING extends X-WING with a third KEM KEM_3 . We instantiate $\text{KEM}_3 = \text{ML-KEM-1024}$ as the recommended third component (Section 4.2 discusses the alternative).

Construction 1 (Z-WING). Let $\text{KEM}_1 = \text{X25519}$ (DH-as-KEM), $\text{KEM}_2 = \text{ML-KEM-768}$, $\text{KEM}_3 = \text{ML-KEM-1024}$. Let $H : \{0, 1\}^* \rightarrow \{0, 1\}^{256}$ be a hash function modelled as a random oracle.

KGen. Sample $(pk_i, sk_i) \leftarrow \text{KEM}_i.\text{KGen}$ for $i \in \{1, 2, 3\}$. Output $pk = (pk_1, pk_2, pk_3)$, $sk = (sk_1, sk_2, sk_3, pk)$.

Encap(pk). Sample ephemeral KEM_1 keypair (pk'_1, sk'_1) . Compute $ss_1 \leftarrow \text{KEM}_1.\text{DH}(sk'_1, pk_1)$, $(c_2, ss_2) \leftarrow \text{KEM}_2.\text{Encap}(pk_2)$, $(c_3, ss_3) \leftarrow \text{KEM}_3.\text{Encap}(pk_3)$. Set $c \leftarrow (pk'_1, c_2, c_3)$ and

$$ss \leftarrow H(\text{"Z-Wing-v1"} \parallel ss_1 \parallel ss_2 \parallel ss_3 \parallel c \parallel pk).$$

Output (c, ss) .

Decap(sk, c). Parse $c = (pk'_1, c_2, c_3)$. Compute ss_1, ss_2, ss_3 as above using sk , then recompute ss via H .

Combiner is robust. The combiner $H(\text{label} \parallel ss_1 \parallel ss_2 \parallel ss_3 \parallel c \parallel pk)$ is binding on all component ciphertexts and public keys, so the security reduction (Section 5) goes through whenever any single component is sound (Lemma 1 in the companion proof). The label "Z-Wing-v1" is a domain separator preventing cross-version key reuse.

4.1 Transport binding

In ZAP, Z-WING keys never appear in isolation. The transport key derivation is

$$K_{\text{tx}} \leftarrow \text{HKDF-Expand}(\text{HKDF-Extract}(0, ss), \tau_{\text{ZAP}}, \ell)$$

where τ_{ZAP} contains: (i) the protocol label, (ii) both peers' long-term public-key fingerprints (32-byte SHA-3-256 truncations), (iii) the Z-WING ciphertext, (iv) both ephemeral public keys (the X25519 ephemeral and the ML-KEM ciphertext), (v) the negotiated cipher-suite identifier, and (vi) any session-context nonces sampled during the handshake.

The fingerprint binding (point (ii)) is what makes ZAP's use of Z-WING *authenticated* rather than only confidential: a man-in-the-middle that swaps a peer's static pk for one of its own choosing is detected because the computed K_{tx} no longer matches the value the legitimate peer derives.

4.2 Choice of third component

We considered two candidates for KEM_3 .

ML-KEM-1024. Larger parameter set of the same module-lattice family, NIST-standardised under FIPS 203 [6]. Public key 1568 B, ciphertext 1568 B, encap/decap ~ 0.4 ms on x86_64. Sharing the algebraic structure of KEM_2 is a known weakness of this choice; we mitigate this by relying on KEM_3 's *larger* concrete margin (Cat 5) rather than on independence of the algebraic family.

Classic McEliece. Code-based, with a ~ 50 -year track record [7, 8]. Independent of lattice assumptions, which is genuinely valuable in a hybrid. Drawback: 1 MB-class public keys make it unworkable for short-lived sessions and impose a hard cap on handshakes-per-second.

Decision. For ZAP, where *handshake throughput* matters (short-lived RPC, mobile, IoT), ML-KEM-1024 is the correct choice. The combiner's robustness gives us defence against future lattice cryptanalysis through Cat-5 margin; defence against catastrophic break of the entire lattice family is provided by $\text{KEM}_1 = \text{X25519}$, which is independent. We leave "Z-WING-CMc" (a variant for environments that can amortise McEliece public keys) as an out-of-band extension.

5 Security Analysis

Theorem 2 (Z-WING IND-CCA2 (informal)). *For any quantum-polynomial-time adversary $\mathcal{A}$ against the IND-CCA2 security of Z-WING making at most q_H random-oracle queries and q_D decapsulation queries,*

$$\text{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{A}) \leq \min_{i \in \{1,2,3\}} \text{Adv}_{\text{KEM}_i}^{\text{kem}}(\mathcal{B}_i) + \frac{q_H + q_D}{2^{256}} + q_D \cdot \text{negl},$$

where $\mathcal{B}_i$ is an adversary against KEM_i with running time $\approx t(\mathcal{A})$.

Theorem 3 (ZAP IND-CCA2-AKE (informal)). *For any QPT adversary $\mathcal{A}$ against the AKE security of ZAP instantiated with Z-WING, with n_P parties, n_S sessions per party, q_H random-oracle queries, and q_D decapsulation queries,*

$$\text{Adv}_{\text{ZAP[Z-WING]}}^{\text{ake}}(\mathcal{A}) \leq 2n_P n_S \cdot \text{Adv}_{\text{Z-WING}}^{\text{ind-cca}}(\mathcal{B}) + \frac{n_S^2}{2^{|\text{nonce}|}} + \text{Coll}_H,$$

where $\text{Coll}_H \leq \binom{q_H}{2} \cdot 2^{-256}$.

The proofs are in the companion document (`proofs/pq-hybrid-kem/proof.tex`). The reduction proceeds via a four-game hop: $\mathbf{G}_0$ is the real AKE game; in $\mathbf{G}_1$ we replace the ML-KEM-768 shared secret in the test session with uniform; in $\mathbf{G}_2$ likewise for ML-KEM-1024; in $\mathbf{G}_3$ likewise for X25519. The hybrid freshness condition guarantees that at least one of these hops is sound, hence $\mathbf{G}_3$ is information-theoretically random and the adversary's advantage is bounded by the corresponding KEM advantage plus collision/repetition terms.

6 HNDL Analysis

Suppose an adversary records, today, every ZAP handshake on a target link. Define the *HNDL window* as the time after which the adversary's quantum capability becomes operationally relevant; we assume T_Q years. Per-session, the storage burden is

$$S_{\text{sess}} \approx |pk'_1| + |c_2| + |c_3| + |\tau_{\text{ZAP}}| \approx 32 + 1088 + 1568 + \mathcal{O}(256) \text{ bytes} \approx 3 \text{ KB},$$

which over a 10 Gb/s link with $\sim 10^4$ handshakes/s amounts to ~ 1 TB/day of stored ciphertext. This is operationally feasible for a nation-state but uneconomic for casual logging.

The relevant probability is that an adversary, at time T_Q , can recover the session key from logged ciphertexts. With three independent components and the freshness assumption, this probability is bounded by $\min_i \mathbf{Adv}_{\text{KEM}_i}^{\text{kem}}(\mathcal{B}_i^{T_Q})$, where the adversary is now quantum. Because $\text{KEM}_1 = \text{X25519}$ is broken in QPT and ML-KEM is conjectured PQ-secure, the bound becomes $\mathbf{Adv}^{\text{ml-kem}}(\mathcal{B}_2^{T_Q}) + \mathbf{Adv}^{\text{ml-kem-1024}}(\mathcal{B}_3^{T_Q})$, which is the lattice security of the smaller of the two parameter sets.

This is exactly the HNDL guarantee we want: even if curves are dead by T_Q , the lattice components keep the channel confidential.

7 Performance Budget

Table 1 summarises wire size and Table 2 CPU cost. Wire bytes are for a single side’s contribution (the responder mirrors the initiator). CPU figures are from the public AVX2 implementations of ML-KEM and X25519 on a Skylake-class core; Z-WING is the sum of its parts plus a single SHA3-256 invocation over ~ 4 KB.

Table 1: Handshake bytes-on-the-wire (one side).

Construction	Public key	Ciphertext	Total/side
X25519 only	32	32	64
ML-KEM-768 only	1184	1088	2272
X-WING	1216	1120	2336
Z-WING (this work)	2784	2688	5472

Table 2: CPU cycles (Skylake AVX2, single core).

Construction	KGen	Encap	Decap
X25519 only	80 k	80 k	80 k
X-WING	220 k	240 k	280 k
Z-WING	430 k	470 k	540 k

A full ZAP handshake with Z-WING therefore costs roughly ~ 5.5 KB each way (~ 11 KB round-trip) and ~ 1 million cycles each side, $\sim 6\times$ the wire bytes and $\sim 12\times$ the CPU of an X25519-only baseline. For comparison, X-WING alone is ~ 3 KB each way. We deem this acceptable for sessions whose lifetime is measured in minutes or longer, or for the small fraction of sessions that explicitly opt into long-term confidentiality.

8 Related Work

KEM combiners and their security under partial corruption are the subject of [5], who give a generic IND-CCA combiner and prove its security in the random-oracle model. Our Z-WING combiner is structurally the same (parallel encap, hash of all component shared secrets and ciphertexts) but with the addition of public-key binding to defeat the “share-the-ciphertext” attacks identified for naive combiners. [4] extend hybrid KEM analyses to authenticated key exchange and motivate the freshness condition we adopt in Section 2.

The choice of X25519 || ML-KEM-768 specifically is the same one made by BoringSSL’s X25519MLKEM768 hybrid [9] and by IETF/CFRG’s X-WING draft [2]. Larger hybrids that

include ML-KEM-1024 or Classic McEliece have been considered in the IETF TLS hybrid-design space but have not been standardised; Z-WING is, to our knowledge, the first concretely specified triple-hybrid for a NIKE-style transport handshake.

The earlier post-quantum-era hybrid Frodo-with-curves construction [10] predates standardisation and is no longer performance-competitive. NIST guidance [11, 12] permits hybrid PQ deployment as a transitional posture; Z-WING should be read as both transitional and conservative-default for the long-lived-session class.

Cremers and collaborators’ symbolic AKE analysis [13, 3, 14] provides the verification framework we anticipate using to mechanise the proofs sketched here. The textbook by Boyd, Mathuria and Stebila [15] contains the AKE security model formulations we adopt.

9 Conclusion and Open Questions

We have specified Z-WING, a triple-hybrid PQ KEM that strictly extends X-WING with a third, conservatively-chosen lattice component, and given a modular IND-CCA2-AKE security argument for its use in the ZAP transport handshake. The construction is robust under partial corruption: as long as *any one* of X25519, ML-KEM-768, or ML-KEM-1024 remains sound for a given session, the channel is secure. The wire and CPU costs are modest enough that ZAP can deploy Z-WING as default for long-lived sessions and as opt-in for short-lived ones.

Open questions.

- *Mechanised verification.* The reduction in our companion proof is hand-checked. A Tamarin / EasyCrypt mechanisation, especially of the hybrid-freshness condition, is an obvious next step.
- *Code-based slot.* A Z-WING-CMc variant with Classic McEliece in the third slot is attractive for fixed-identity, low-handshake-rate deployments (e.g. enclave attestation, root-of-trust establishment). The public-key transport can be amortised via a separate static-key fetch channel; quantifying that cost is future work.
- *Forward secrecy under post-handshake corruption.* The analysis here covers the standard AKE freshness conditions; tighter forward-secrecy guarantees against quantum corruption of static keys *after* handshake completion deserve a separate treatment.
- *Tightness.* The factor $2n_{pnS}$ in Theorem 3 is the standard guess-the-test-session bound. A tight multi-user reduction for Z-WING would mirror the multi-user MAC literature.

References

- [1] Michele Mosca. “Cybersecurity in an Era with Quantum Computers: Will We Be Ready?” In: *IEEE Security & Privacy*. Vol. 16. 5. 2018, pp. 38–41.
- [2] Manuel Barbosa et al. *X-Wing: The Hybrid KEM You’ve Been Looking For*. Cryptology ePrint Archive, Paper 2024/039. 2024. URL: <https://eprint.iacr.org/2024/039>.
- [3] Cas Cremers et al. “A Comprehensive Symbolic Analysis of TLS 1.3”. In: *ACM CCS*. 2017, pp. 1773–1788.
- [4] Nina Bindel et al. “Hybrid Key Encapsulation Mechanisms and Authenticated Key Exchange”. In: *Post-Quantum Cryptography – PQCrypto*. Vol. 11505. LNCS. 2019, pp. 206–226.
- [5] Federico Giacon, Felix Heuer, and Bertram Poettering. “KEM Combiners”. In: *Public-Key Cryptography – PKC 2018*. Vol. 10769. LNCS. 2018, pp. 190–218.

- [6] NIST. *FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard*. 2024.
- [7] Robert J. McEliece. “A Public-Key Cryptosystem Based on Algebraic Coding Theory”. In: *DSN Progress Report 42-44, Jet Propulsion Laboratory*. 1978.
- [8] Daniel J. Bernstein et al. *Classic McEliece: Conservative Code-Based Cryptography*. NIST PQC submission, Round 4. 2022.
- [9] Google. *X25519MLKEM768: BoringSSL hybrid key agreement*. <https://boringssl.googlesource.com/boringssl/>. 2024.
- [10] Joppe W. Bos et al. “Frodo: Take off the Ring! Practical, Quantum-Secure Key Exchange from LWE”. In: *ACM CCS*. 2016, pp. 1006–1018.
- [11] David A. Cooper et al. *NIST SP 800-208: Recommendation for Stateful Hash-Based Signature Schemes*. 2020. DOI: 10.6028/NIST.SP.800-208.
- [12] Gorjan Alagic et al. *Status Report on the Third Round of the NIST Post-Quantum Cryptography Standardization Process*. NIST IR 8413. 2022. DOI: 10.6028/NIST.IR.8413.
- [13] Cas Cremers. “Session-state Reveal Is Stronger than Ephemeral Key Reveal: Attacking the NAXOS Authenticated Key Exchange Protocol”. In: *ACNS*. 2009, pp. 20–33.
- [14] Simon Meier et al. “The TAMARIN Prover for the Symbolic Analysis of Security Protocols”. In: *CAV*. Vol. 8044. LNCS. 2013, pp. 696–701.
- [15] Colin Boyd, Anish Mathuria, and Douglas Stebila. *Protocols for Authentication and Key Establishment*. Second. Springer, 2020.